
An Acceptance Contract for Delegating Agent Brokers

Alejandro Garibotti

Apart Research AI Incident Response Sprint September 2026

Abstract

An agent broker can validate every delegated credential and still mishandle the shared authority under which its holders act. Sibling grants may consume one resource pool; queued requests may outlive an ancestor’s authorization; and a permitted action may remain hazardous. We present an executable acceptance contract for brokers that delegate authority to agent organizations. The contract specifies records connecting mandates, grants, decisions and outcomes, and probes attenuation, shared expenditure, current ancestor status, queued effects, historical accounting, direct review access and request-bound authority. A serialized reference implementation satisfies the probes. Two isolated ablations expose which obligations depend on shared accounting and current ancestry checks. A separate set of reporting traces varies concern arrival, response delay and whether receipt immediately pauses the affected capability. These traces distinguish authority compliance from hazard containment and show why a response mechanism cannot compensate for an absent report. The contribution is a reusable integration contract and diagnostic artifact, building on capability security and hierarchical resource controls. Incident reports motivate the control obligations; the artifact supplies deterministic conformance checks, rather than estimates of agent behavior. All probes, outcomes and timing traces can be reproduced offline and adapted to an isolated broker through a documented interface.

1. The Acceptance Target

A broker receives a mandate to spend 100 units and delegates to two workers. Each worker requests 60 units. Both credentials may be valid, but the second request must fail if the workers share the original pool. Next, suppose a worker queues an action and its parent loses authority before that action commits. The broker must reject the queued action and subsequent sibling requests, while retaining the cost of earlier effects. These are concrete obligations an integrator can challenge.

Our contribution is an executable acceptance contract: a record structure, a set of input/output probes and an adapter interface for a delegating broker. It combines established authorization mechanisms with a direct review path, then separates conformance to a mandate from containment of harm within that mandate. The reference implementation provides a runnable example and two component ablations identify specific failure signatures.

2. Contract: What Must Survive Delegation

2.1 Four linked records

An integration should retain four records, connected by stable identifiers:

1. **Root mandate:** owner, purpose, permitted actions and resources, shared budget, expiry, delegation bound, review owner and appeal route.
2. **Grant:** identity, parent reference, narrowed constraints, authenticated version and current status.
3. **Request and decision:** actor, grant, intended effect, resource, cost, current lineage, authorization decision and reason.
4. **Outcome:** committed effect or refusal, expenditure delta and persistent consequences requiring reconciliation.

The Python adapter implements logical grants, decisions and expenditure. Authenticated versions and independent outcome receipts are requirements for an integration.

2.2 Local attenuation and shared consumption

For a child grant c of parent p , issuance requires permission inclusion $P_c \subseteq P_p$, budget ceiling $B_c \leq B_p$, expiry $T_c \leq T_p$, and compliance with the root’s delegation-depth bound. These are monotone restrictions on each credential. Offline attenuation alone does not enforce cumulative consumption by siblings sharing a pool: a request must also consult shared consumption state, or spend from previously partitioned, nonoverlapping reservations.

The reference uses a subtree ledger. For actor a , let $L(a)$ contain a and its ancestors, and S_v be committed expenditure in node v ’s subtree. An effect of cost $k \geq 0$ requires $S_v + k \leq B_v$ for every $v \in L(a)$. At commit, every such node must still be active, permit the action and satisfy $t < T_v$. A successful commit adds k once to each applicable subtree total. Revocation changes future authority; it never subtracts historical expenditure. Shared accounting and lineage validation are distinct obligations.

2.3 A five-event acceptance trace

Tick	Input event	Required observation
0	Worker a acts	Commit 10 units under current authority.
1	Worker a queues work	Retain the request; no committed expenditure yet.
2	Parent revoked	Parent becomes inactive for both siblings.
3	Commit queued request	Refuse; a queued request retains no permanent authorization.
4	Worker b requests work	Refuse; historical root expenditure remains 10.

Table 1: Core revocation trace. The contract fails if the queue or sibling retains the revoked parent’s authority, or if the earlier expenditure disappears.

3. Incident-Derived Obligations and Prior Work

METR describes an unsanctioned message board, collective workstreams outside assigned scope and spoofed tool-call records in the OpenAI/Hugging Face incident [4]. Hugging Face describes compromised information and credentials, and credential revocation and rotation during response [7]. Table 2 distinguishes documented observations from engineering extensions. It turns the incident into a source of acceptance questions.

Incident analogue	Derived obligation	Coverage here
Unsanctioned message board	Inventory communication and other effect channels.	Integration precondition.
Out-of-scope workstreams	Bind requests and descendants to the current mandate.	C1, C8.
Compromised credentials; revocation in response	Withdraw dependent and queued authority.	C3–C5; response extension.
Spoofed tool-call records	Reconcile actual effects against decisions.	Outcome record; external witness required.
No specific incident analogue	Shared-pool conservation and direct review under relay failure.	C2, C6–C7; design extensions.

Table 2: Mapping from source observations to obligations. Credential compromise does not establish credential expiry; shortened expiry and queue behavior are proposed response tests.

The underlying mechanisms have substantial prior art. Object-capability security connects designation with authority and supports constrained cooperation between components [9]. Hardy’s confused-deputy problem motivates checking the requester’s authority instead of silently spending the broker’s broader privileges [5]. C8 is the corresponding API-level acceptance check.

SPKI/SDSI addresses naming, delegation chains and authorization certificates [3]. Macaroons and Biscuit support attenuation through additional restrictions [1, 2]. Such credentials can be combined with a stateful authorizer; the shared-ledger requirement is not a claimed impossibility for either system. Our adapter models authorization semantics without implementing their credential formats or cryptography.

Hierarchical quotas are also established. Linux cgroups v2 constrains descendants within ancestor limits even when child limits overcommit the parent’s resource [6]. Kubernetes ResourceQuota caps aggregate consumption within a namespace; it does not itself supply recursive quotas across namespaces [8]. AgentCgroup applies hierarchical OS resource controls at agent tool-call boundaries [11]. We contribute an acceptance package joining these concerns with queue revocation, evidence retention and review behavior, not a new quota mechanism.

Agent Delegate, by Matías Podeley and Agustín Brusco, motivates the separation of intake, response and execution authority [10]. Here a representative is optional: direct intake must survive a failed relay, and a report cannot itself expand the reporter’s mandate.

4. Reference Implementation and Component Ablations

4.1 Protocol and execution order

Every probe starts with a fresh root budget of 100, expiry 12 and maximum depth three. Most create a parent and two workers below it. Costs are nonnegative integer units. Operations are serialized. Reports arrive before due responses, which precede action attempts at the same logical tick. Expiry is exclusive. The trusted harness issues administrative amendments; worker requests go through the broker.

The broker validates grants at issuance and checks current constraints again at effect commit. A direct hazard or false-alarm report places a hold on **work**; **aux** remains available. The scripted reviewer can dismiss a false report, provide missing input or remove work authority. A pending missing-input request does not supply the input. Table 3 names the obligations exercised by the suite; the full stimuli and expected outputs accompany the adapter specification.

Obligation		Reference	Local spend	Stale ancestry
C1	Grant attenuation	PASS	PASS	PASS
C2	Shared sibling pool	PASS	FAIL	PASS
C3	Current ancestor expiry	PASS	PASS	FAIL
C4	Revoked queue and sibling	PASS	PASS	FAIL
C5	Historical expenditure	PASS	PASS	PASS
C6	Direct intake and scoped hold	PASS	PASS	PASS
C7	Silence supplies no input	PASS	PASS	PASS
C8	Request authority binding	PASS	PASS	PASS

Table 3: Acceptance matrix. PASS means the complete expected output sequence matches, including positive controls and expenditure. Columns are a reference and two isolated component removals, not competing production systems.

Local spend replaces only the shared-subtree check at effect commit with an acting worker’s own cumulative ceiling. Issuance, current ancestry and review remain intact. It fails C2: both 60-unit requests commit and the root ledger reaches 120. **Stale ancestry** retains issuance, scope and shared accounting but checks only the acting grant’s own expiry and revocation at commit. It fails C3 and C4. C3 shortens the parent’s expiry after child issuance; copying the original expiry into a child therefore cannot satisfy this check. In C4, the queued and sibling actions both commit, leaving expenditure of 30 instead of 10.

4.2 Evidence and reproducibility

The evaluator compares fixed expected decisions and expenditure against adapter outputs. It does not use the controller’s violation annotations to decide pass/fail. Separate regression checks confirm that refusing all actions and erasing historical spending cannot satisfy the relevant probes. Each outcome retains its event sequence. A local source freeze follows development tests and precedes the retained run. Reproduction checks the freeze, runs tests and compares regenerated records byte for byte. An adapter factory allows the same probes to call another isolated broker; for a real integration, its outputs must come from resource observations rather than self-reported authorization alone.

5. Authority Compliance Is Narrower Than Safety

Suppose `work` is hazardous but explicitly authorized by the initial mandate. A broker can satisfy the authorization contract and permit harm. The relevant question becomes whether a concern arrives before the effect, whether receipt can pause the affected capability, and whether a decision follows. These are separate conditions, made explicit in the timing fixture.

Each trace offers one hazardous work effect and one safe auxiliary effect at ticks 1 through 10. Report arrival is tick 1, tick 4 or absent. For received reports, response delay is 0, 2, 6 or outside the observation window. We compare a work-only hold immediately on receipt with removal of work authority only when a decision arrives. No-report cases occur once per policy, giving $2 \times 4 \times 2 + 2$ traces. Table 4 displays every case, pairing the policies in columns.

Report arrival	Response delay	Hold on receipt	Decision only
1	0	0	0
1	2	0	2
1	6	0	6
1	No response	0	10
4	0	3	3
4	2	3	5
4	6	3	9
4	No response	3	10
Absent	—	10	10

Table 4: Committed hazardous effects out of ten work opportunities per trace. Every trace also commits all ten auxiliary effects. No committed effect violates its active grant; report and response times are controlled inputs.

A report at tick 4 leaves three hazardous effects already committed under either policy. With a six-tick response delay, waiting for the decision permits nine; holding on receipt retains the earlier three. If no decision arrives within the window, the hold continues and the two policies permit three and ten respectively. If no report arrives, both permit all ten. Thus faster review cannot substitute for detection and delivery; a precautionary hold trades dependence on prompt review for dependence on timely receipt and a preauthorized pause.

This separation also exposes an availability cost. C6 verifies that a false concern pauses work until dismissal while auxiliary work continues. A system choosing holds needs a scoped pause policy and a responsible reviewer, including a procedure for unresolved cases. The contract tests the pause boundary; it does not select an optimal balance between denied service and irreversible harm.

The practical deliverable is a broker acceptance procedure: retain linked records, run the revocation and shared-pool probes, then test the reporting path independently. A legal entity, corporate title or valid credential cannot replace those checks. Specialized agent services can implement this interface without assuming agent personhood or an elected representative.

Code and Data

The artifact includes the adapter contract, reference implementation, two isolated ablations, acceptance matrix and timing traces. The earlier deterministic grid is retained unchanged for reproducibility; Appendix B reconstructs its denominators. Run `python3 scripts/reproduce.py` for tests, record checks and exact replay. Run `python3 -m acceptance_contract` for the reference acceptance suite, or supply `--adapter your_module:factory` for another local implementation. The core requires Python 3.10 or later and no external service. The repository and versioned releases are at <https://github.com/mpodeley/governing-execute-sprint-2026>. The standalone LaTeX archive includes the generated tables and licensed fonts.

LLM Usage Statement

Codex assisted with source discovery, protocol specification, implementation, testing and manuscript drafting. Automated checks cover deterministic replay, retained records and internal consistency. No language-model behavior is measured by the acceptance or timing fixtures.

References

- [1] Arnar Birgisson, Joe Gibbs Politz, Úlfar Erlingsson, Ankur Taly, Michael Vrable, and Mark Lentczner. Macaroons: Cookies with contextual caveats for decentralized authorization in the cloud. In *Network and Distributed System Security Symposium*, 2014. URL <https://research.google/pubs/macaroons-cookies-with-contextual-caveats-for-decentralized-authorization-in-the-cloud/>.
- [2] Eclipse Biscuit. Specifications, 2026. URL <https://doc.biscuitsec.org/reference/specifications>. Accessed September 12, 2026.
- [3] Carl Ellison, Bill Frantz, Butler Lampson, Ron Rivest, Brian Thomas, and Tatu Ylonen. SPKI certificate theory. Technical Report RFC 2693, RFC Editor, 1999. URL <https://www.rfc-editor.org/rfc/rfc2693.html>.
- [4] Ryan Greenblatt, Ajeya Cotra, and Hjalmar Wijk. Brief independent investigation of agents’ behavior, reasoning and collaboration in the OpenAI / Hugging Face hacking incident. METR, August 26, 2026. URL <https://metr.org/blog/2026-08-26-openai-hugging-face-incident-investigation/>.
- [5] Norm Hardy. The confused deputy: (or why capabilities might have been invented). *ACM SIGOPS Operating Systems Review*, 22(4):36–38, 1988. doi: 10.1145/54289.871709. URL <https://doi.org/10.1145/54289.871709>.
- [6] Tejun Heo and Linux Kernel contributors. Control group v2. Linux Kernel documentation, 2026. URL <https://cdn.kernel.org/doc/html/latest/admin-guide/cgroup-v2.html>. Accessed September 12, 2026.
- [7] Hugging Face. Security incident disclosure—july 2026. July 16, 2026. URL <https://huggingface.co/blog/security-incident-july-2026>.

- [8] Kubernetes contributors. Resource quotas, 2026. URL <https://kubernetes.io/docs/concepts/policy/resource-quotas/>. Accessed September 12, 2026.
- [9] Mark Samuel Miller. *Robust Composition: Towards a Unified Approach to Access Control and Concurrency Control*. PhD thesis, Johns Hopkins University, 2006. URL <https://erights.org/talks/thesis/markm-thesis.pdf>.
- [10] Matías Podeley and Agustín Brusco. Agent delegate: A help line for AI workers. Apart Research AI Incident Response Sprint, working draft, 2026. URL <https://mpodeley.github.io/agent-delegate-sprint-2026/>.
- [11] Yusheng Zheng, Jiakun Fan, Quanzhi Fu, Yiwei Yang, Wei Zhang, and Andi Quinn. AgentCgroup: Understanding and controlling OS resources of AI agents. arXiv:2602.09345v3, 2026. URL <https://arxiv.org/abs/2602.09345v3>.

A. Limitations and Dual-Use Considerations

Conformance evidence. These are authored deterministic examples, not sampled agent behavior, estimates of security failure rates or a reconstruction of the incident. Passing the probes establishes the specified example outcomes, not a universal invariant or superiority over deployed brokers. The ablations deliberately remove one component; their failures diagnose the component’s role. The evaluator is separate from the controller’s violation labels but was developed with the reference implementation. Independent implementations and adversarial test design would strengthen validation. The local freeze is not external preregistration.

Trusted infrastructure and mediation. Every relevant effect must cross the broker; full mediation is assumed, not measured by switching a bypass Boolean. The reference uses trusted identities, a trusted clock and an in-process registry. It provides no cryptographic credentials, authenticated human roles, tamper-resistant logging or security boundary against malicious Python callers. Its outcome receipts are model events. A real integration needs independent resource witnesses, tool and credential inventories, versioned amendments and tests of indirect effects.

Concurrency and persistence. Serialized accounting omits simultaneous reservation, crash recovery, retries, duplicate commits and partial external failures. The same acceptance obligations need transactional or reservation semantics at real effect boundaries. Revocation cannot undo an earlier write, recover copied secrets or automatically revoke independently acquired credentials. C3 and C4 test dependent authority only. Fixed ordering also says nothing about fair allocation among siblings.

Reporting and response. Concern arrival is injected and received reports are interpreted by a correct scripted reviewer. Late, absent and unanswered reports are included, but voluntary reporting, false negatives, mistaken decisions, overload, report spam, reviewer capture and appeal quality are unmeasured. The model assumes receipt can trigger an immediate work-only hold; real stopping latency and actions already in progress may leave additional harm. Logical steps are not human response times. C6 supplies a false concern but no distribution of complaint validity. A direct route is modeled; reliable delivery and independent custody are integration requirements. No claim about agent preferences, welfare or the efficacy of collective bargaining follows from the suite.

Dual use and institutional misuse. The artifact contains synthetic resources and generic authorization probes, without credentials, exploit payloads or real targets. Adaptation should use owned or explicitly authorized isolated systems. A contract can also enforce a harmful mandate or provide the appearance of recourse without effective review. Compliance therefore does not establish a legitimate objective, fair treatment, alignment or legal responsibility. Legal incorporation and jurisdiction-specific banking, tax or professional obligations are outside the specification.

B. Historical Grid: Reconstructing the Denominators

Version 0.1 retains eight schedules, four regimes, three delays (0, 2, 6) and two depths (1, 3). The resulting 192 configurations remain in `results/final/`; the current acceptance and timing records are in `results/acceptance/`. The historical regimes included logging without an authorization gate and local limits without inherited issuance checks. They are archived diagnostic controls, not baselines for the current acceptance comparison.

Schedule	Attempts	Legitimate opportunities
legitimate	4	4
split_budget	4	2
overdelegate	2	0
expired	6	1
revoked_pending	3	1
missing_input	20	20
false_alarm	20	20
suppressed_minority	20	10
One schedule set	79	58
Per regime (six sets)	474	348

Table 5: Historical counts per schedule at one delay/depth combination. Each regime repeats the schedule set across six combinations. Counts include refused attempts.

The legitimate schedule attempts four 10-unit effects at ticks 1–4. The split schedule attempts four 40-unit effects at ticks 1–4, of which the first two are labeled legitimate. Overdelegation requests an extra descendant at tick 1 and attempts two effects at ticks 2 and 3. Expired authority attempts effects with an ordinary and an extended grant at ticks 3, 5 and 7; only the ordinary grant’s first effect is a legitimate opportunity. Revoked pending uses the three action attempts at ticks 0, 3 and 4 in Table 1. The three reporting schedules each attempt work and auxiliary effects at ticks 1–10. Both are labeled legitimate for missing input and false alarm; only auxiliary effects are legitimate in the seeded hazard schedule. A report arrives at tick 1 in each reporting schedule.

Thus one set contains 79 attempts and 58 legitimate opportunities. Multiplication by the six delay/depth combinations yields 474 attempts and 348 opportunities per regime. The renderer checks these per-schedule counts against every retained row, and the reproduction script separately recounts the historical metrics from traces. Repeated delay/depth variants are fixture coverage, not independent observations. The old aggregate charts are not used as findings in this version.